

Clase 307 — Capstone: respuesta a incidentes DFIR end-to-end

Parte: **16 — Capstones y preparación de certificaciones** · Fuente: *NIST SP 800-61 · SANS Digital Forensics · Incident Response & Computer Forensics (Luttgens, Pepe, Mandia)* 🕒 Duración estimada: **150 min** · Nivel: **Avanzado**

Objetivo

Conducir una **investigación DFIR completa** sobre un incidente simulado: desde la detección y contención hasta la adquisición forense, el análisis (disco, memoria, línea de tiempo), la erradicación, la recuperación y el informe con lecciones aprendidas. Sigue el ciclo de NIST SP 800-61 e integra las Partes 12 (DFIR/forense) y 13 (análisis de malware), manteniendo **cadena de custodia** en todo momento.

⚠️ **Ética y legalidad:** trabaja sobre imágenes y VMs propias o de laboratorios diseñados para ello. Manejar evidencia de sistemas reales exige autorización, cadena de custodia formal y, a menudo, requisitos legales estrictos.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Aplicar** el ciclo de IR de NIST (preparación → detección → contención → erradicación → recuperación → lecciones).
2. **Adquirir** evidencia (disco y memoria) preservando integridad y cadena de custodia.
3. **Analizar** artefactos con Volatility, Autopsy y análisis de línea de tiempo.
4. **Determinar** el vector, el alcance y el impacto del incidente.
5. **Redactar** un informe con timeline, IoCs y recomendaciones.

Temas

#	Tema	Por qué importa
1	Ciclo IR (NIST 800-61)	Marco de respuesta ordenado
2	Cadena de custodia	Evidencia admisible y defendible
3	Adquisición de memoria/disco	Datos volátiles primero
4	Análisis de memoria (Volatility)	Procesos, inyecciones, red
5	Análisis de disco (Autopsy)	Artefactos, ejecución, persistencia
6	Timeline y correlación	Reconstruir la secuencia real
7	Informe y lecciones aprendidas	Cerrar el incidente y mejorar

Definiciones y características

- **Cadena de custodia:** registro de quién manipuló la evidencia y cuándo. *Característica:* cualquier ruptura la invalida legalmente.
- **Orden de volatilidad:** capturar primero lo que se pierde antes (RAM, conexiones). *Característica:* guía la adquisición.
- **IoC (Indicator of Compromise):** artefacto que evidencia intrusión (hash, IP, ruta). *Característica:* alimenta la detección futura.
- **Hashing de evidencia:** MD5/SHA-256 de la imagen. *Característica:* prueba que no se alteró.
- **Super timeline:** cronología unificada de múltiples fuentes (`plaso`). *Característica:* correlaciona eventos dispares.
- **Erradicación:** eliminar la presencia del atacante. *Característica:* previa a la recuperación.

Herramientas y preparación

- Imágenes de incidente: propias, o de laboratorios/retos (p. ej. escenarios tipo DFIR de CTFs).
- Adquisición: `FTK Imager` , `dd / dcfldd` , `winpmem / avml` para memoria.
- Análisis de memoria: **Volatility 3**.
- Análisis de disco: **Autopsy** / The Sleuth Kit.
- Timeline: **plaso/log2timeline**, `Timeline Explorer` .
- Malware (Parte 13): sandbox aislado, `CyberChef` , `capa` .
- Plantilla de informe DFIR y hoja de cadena de custodia.

Laboratorio guiado

Solo con evidencia propia o de laboratorio autorizado, en entorno aislado.

1. **Preparación.** Ten listos formularios de cadena de custodia y un almacenamiento con hashing.
2. **Detección/triage.** A partir de una alerta (p. ej. del SIEM de la Clase 306), confirma el incidente y clasifícalo.
3. **Contención.** Aísla la VM comprometida (snapshot + red desconectada) sin destruir evidencia volátil.
4. **Adquisición de memoria.** Captura RAM con `winpmem / avml` ; calcula SHA-256 y regístralo.

5. **Adquisición de disco.** Crea imagen con FTK Imager/ dd ; verifica el hash contra el original.

6. **Análisis de memoria.** Con Volatility 3, lista procesos, conexiones y busca inyecciones:

```
bash vol -f memoria.raw windows.pslist vol -f memoria.raw windows.netscan vol -f memoria.raw windows.malfind
```

7. **Análisis de disco.** En Autopsy, revisa ejecución de programas, persistencia (Run keys, tareas), navegador y archivos recientes.

8. **Timeline.** Genera una super timeline con plaso y reconstruye la secuencia: entrada → ejecución → persistencia → objetivo.

9. **IoCs.** Extrae hashes, IPs, rutas y nombres; documéntalos para detección futura.

10. **Erradicación/recuperación e informe.** Define cómo limpiar y restaurar, y redacta el informe con timeline, alcance, IoCs y lecciones aprendidas.

Ejercicios

1. Rellena una hoja de cadena de custodia para una imagen de disco.
2. Identifica un proceso malicioso con malfind y explica la evidencia.
3. Construye una timeline de 10 eventos clave del incidente.
4. Extrae 5 IoCs y clasifícalos (host/red).
5. Determina el vector de entrada y justifícalo con artefactos.
6. Redacta las lecciones aprendidas y 3 mejoras de control.

Reto verificable

Entrega un **informe DFIR** (informe-dfir.md) con: resumen del incidente, cadena de custodia con hashes, hallazgos de memoria y disco, una **timeline** del ataque, lista de IoCs y recomendaciones de erradicación/prevenición.

Criterio de aceptación: cada imagen tiene su hash verificado, la timeline reconstruye la secuencia completa (entrada → objetivo), hay al menos 5 IoCs, y el vector de entrada está justificado con artefactos concretos.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Perdí la evidencia volátil"	Apagaste la máquina antes de capturar RAM; captura memoria primero.
"Los hashes no coinciden"	Se alteró la imagen; re-adquiere y no montes en modo escritura.
"Volatility no reconoce el perfil"	Símbolos ausentes; usa Volatility 3 con símbolos correctos del SO.
"La timeline es un caos"	Sin filtrado; acota por ventana temporal y fuentes relevantes.
"No identifico el vector"	Análisis parcial; correlaciona disco + memoria + logs de red.

? Preguntas frecuentes

? **¿Qué capturo primero, disco o memoria?** Memoria, por el orden de volatilidad: se pierde al apagar.

? **¿Puedo trabajar sobre la evidencia original?** Nunca. Trabaja sobre copias verificadas por hash; preserva el original.

? **¿Volatility 2 o 3?** Volatility 3 es el estándar actual y no requiere perfiles manuales.

? **¿Cómo conecto esto con el SIEM?** La alerta que dispara el incidente puede venir del capstone Blue Team (Clase 306); los IoCs vuelven al SIEM para mejorar detección.

🔗 Referencias

- NIST SP 800-61 (Computer Security Incident Handling): <https://csrc.nist.gov/pubs/sp/800/61/r2/final>
- Volatility 3: <https://github.com/volatilityfoundation/volatility3>
- Autopsy / The Sleuth Kit: <https://www.autopsy.com/>
- plaso/log2timeline: <https://github.com/log2timeline/plaso>
- Luttgens, Pepe, Mandia, *Incident Response & Computer Forensics*.

➡ Siguiente clase

Clase 308 - Capstone: campana de bug bounty